

إجراءات الاستجابة لحوادث أمن المعلومات

Information Security Incident Response Procedure



بنك الأفق
AL-AFAQ BANK

صلاية استثمارية .. وآفاق عالمية | Global Horizon Banking

إجراءات الاستجابة لحوادث أمن المعلومات Information Security Incident Response Procedure

سري — للاستخدام الداخلي فقط	تصنيف الوثيقة
ISMS-DOC-A05-26-1	مرجع الوثيقة
1.0	الإصدار
12 سبتمبر 2026	تاريخ التقرير
محمد عبدالغني العامري (رئيس فريق الاستجابة للحوادث السيبرانية)	معد الوثيقة
أ. سارة الحربي (مدير أمن المعلومات - CISO)	مالك الوثيقة

سجل المراجعات (Revision History)

الإصدار	التاريخ	معد المراجعة	ملخص التعديلات
1.0	12 سبتمبر 2026	محمد الاصبحي	الإصدار المعتمد الأول لإجراءات الاستجابة لحوادث أمن المعلومات لبنك الأفاق الرقمية وفق ضوابط ISO/IEC 27001:2022 وإطار الأمن السيبراني للبنك المركزي السعودي SAMA CSF.
0.2	29 أغسطس 2026	فريق الاستجابة السيبرانية	تحديث إجراءات الأدلة الجنائية، وآليات احتواء فقدان الأجهزة المحمولة، وبروتوكول مزامنة التوقيات الرقمي NTP.

قائمة التوزيع (Distribution)

الاسم / الجهة	المسمى الوظيفي / الدور
د. نورة القحطاني	الرئيس التنفيذي
أ. عبدالله المحيسن	رئيس مجلس الإدارة ورئيس لجنة المخاطر
أ. سارة الحربي	مدير أمن المعلومات (CISO)
م. خالد السالم	مدير تقنية المعلومات
أ. أحمد الغامدي	مدير إدارة التدقيق والمراجعة الداخلية

الاعتماد والتوقيع (Approval)

الاسم	المنصب	التوقيع	التاريخ
د. نورة القحطاني	الرئيس التنفيذي (CEO)	معتمد إلكترونياً	12 سبتمبر 2026
أ. سارة الحربي	مدير أمن المعلومات (CISO)	معتمد إلكترونياً	12 سبتمبر 2026
أ. عبدالله المحيسن	رئيس لجنة المخاطر ومجلس الإدارة	معتمد إلكترونياً	12 سبتمبر 2026

المحتويات (Contents)

1	المقدمة
2	مخطط انسياب الاستجابة للحوادث
3	اكتشاف الحادث وتحليله
3.1	تقييم الأثر
3.2	تحديد أولويات الحوادث
4	تفعيل إجراءات الاستجابة للحوادث
5	تشكيل فريق الاستجابة للحوادث
5.1	أعضاء فريق الاستجابة للحوادث
5.2	الأدوار والمسؤوليات
5.2.1	قائد الفريق
5.2.2	منسق الفريق
5.2.3	ضابط اتصال الحادث
5.2.4	تقنية المعلومات
5.2.5	العمليات التشغيلية
5.2.6	إدارة المرافق
5.2.7	الصحة والسلامة
5.2.8	الموارد البشرية
5.2.9	تخطيط استمرارية الأعمال
5.2.10	الاتصالات (العلاقات العامة والإعلام)
5.2.11	الشؤون القانونية والتنظيمية
5.3	مصفوفة راسي (RACI)
5.4	إدارة الحوادث ومراقبتها والتواصل بشأنها
5.5	إجراءات التواصل
5.5.1	التواصل الخارجي
5.5.2	التواصل مع وسائل الإعلام
6	احتواء الحادث واستتصاله والتعافي منه والإشعار به
6.1	الاحتواء
6.2	الاستتصال
6.3	التعافي
6.4	الإشعار / الإبلاغ
7	أنشطة ما بعد الحادث
8	الملحق (أ): قائمة جهات الاتصال للاستجابة الأولية
9	الملحق (ب): جهات اتصال خارجية مفيدة
10	الملحق (ج): جدول الأعمال القياسي لاجتماع فريق الاستجابة للحوادث

الأشكال

الشكل 1: مخطط انسياب الاستجابة للحوادث

الجدول

الجدول 1: أولويات الحوادث

الجدول 2: أعضاء فريق الاستجابة للحوادث

الجدول 3: مصفوفة راسي (RACI)

الجدول 4: المتحدثون الرسميون لوسائل الإعلام

الجدول 5: قائمة جهات الاتصال للاستجابة الأولية

الجدول 6: جهات اتصال خارجية مفيدة

1 المقدمة (Introduction)

تُستخدم هذه الوثيقة عند وقوع أي حادث يؤثر على أمن المعلومات في بنك الأفاق الرقمية. والهدف منها هو ضمان استجابة سريعة، وفعالة، ومنظمة لحوادث أمن المعلومات.

يجب استخدام الإجراءات الموضحة في هذه الوثيقة كدليل إرشادي فقط عند التعامل مع الحادث؛ إذ لا يمكن التنبؤ بدقة بطبيعة الحادث أو أثره بمستوى عالٍ من اليقين، ولذلك من المهم إعمال المنطق وحسن التقدير عند اتخاذ الإجراءات اللازمة.

ومع ذلك، تهدف الأطر المحددة هنا إلى المساعدة في اتخاذ الإجراءات الصحيحة بسرعة أكبر واستناداً إلى معلومات أكثر دقة.

تتمثل أهداف الاستجابة للحوادث هذا في:

- تقديم نظرة عامة موجزة حول كيفية تعامل واستجابة بنك الأفاق لأي حادث يؤثر على أمن معلوماتها.
- تحديد الفريق أو الأشخاص المكلفين بالاستجابة للحادث وبيان أدوارهم ومسؤولياتهم.
- توضيح التسهيلات والإمكانات المتاحة للمساعدة في إدارة الحادث.
- تحديد آلية اتخاذ القرارات المتعلقة بالاستجابة للحادث.
- توضيح كيفية إدارة التواصل الداخلي ضمن المنظمة ومع الأطراف الخارجية.
- توفير بيانات الاتصال الخاصة بالشخصيات الرئيسية والجهات الخارجية.
- تحديد الإجراءات المتبعة بمجرد حل الحادث وإنهاء حالة الاستنفار لفرق الاستجابة.

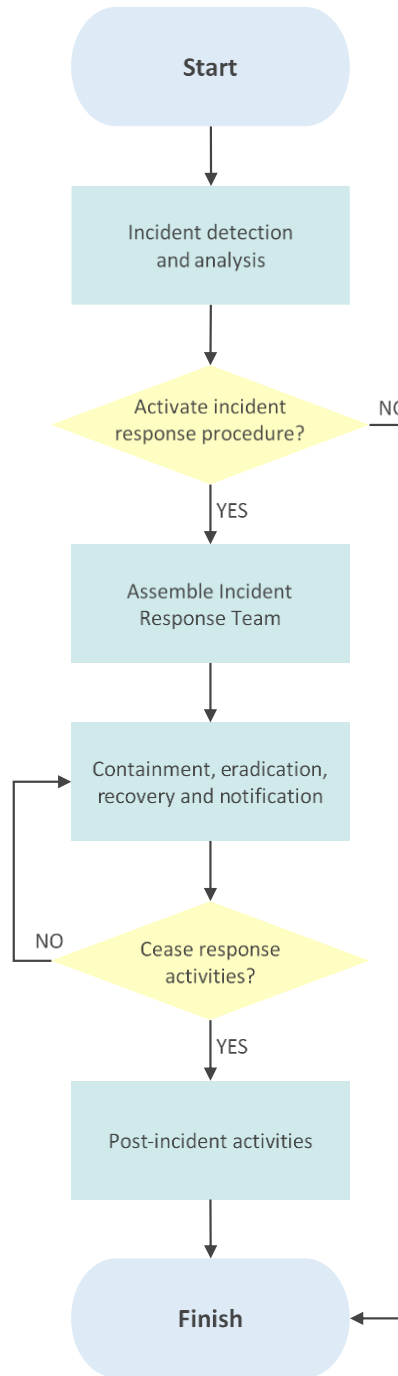
سيتم تسليم نسخة من هذه الوثيقة لجميع الموظفين المذكورة أسماؤهم فيها، ويجب أن تكون متاحة لديهم عند الحاجة إليها.

ستتم مراجعة وتحديث بيانات الاتصال ثلاث مرات سنوياً على الأقل. وأي تغييرات تطرأ على بيانات الاتصال أو أي تفاصيل أخرى ذات صلة خارج هذه المراجعات المجدولة يجب إرسالها إلى incident.response@dhb.sa في أقرب وقت ممكن فور حدوث التغيير.

تُستخدم كافة المعلومات الشخصية التي يتم جمعها كجزء من إجراءات الاستجابة للحوادث والمضمنة في هذه الوثيقة لأغراض إدارة حوادث أمن المعلومات فقط، وتخضع للتشريعات المعمول بها بشأن حماية البيانات.

2 مخطط سير إجراءات الاستجابة للحوادث (Incident Response Flowchart)

يوضح الشكل أدناه التسلسل المنطقي والمراحل المترابطة لإجراءات الاستجابة لحوادث أمن المعلومات في بنك الآفاق الرقمية، والمستندة إلى دورة حياة إدارة الحوادث المعتمدة دولياً في معيار ISO/IEC 27001:2022 وإرشادات NIST SP 800-61:



يتم تفصيل وتوضيح كافة المراحل والإجراءات المذكورة في المخطط بشكل دقيق في الأقسام اللاحقة من هذه الوثيقة.

3 اكتشاف الحادث وتحليله (Incident Detection and Analysis)

قد يتم اكتشاف الحادث في البداية بطرق متنوعة ومن خلال مصادر مختلفة، وذلك وفقاً لطبيعة الحادث ومكانه. حيث يمكن اكتشاف بعض الحوادث ذاتياً عبر الأدوات والبرمجيات المستخدمة داخل بنك الأفاق أو عبر ملاحظة الموظفين لأي نشاط غير معتاد (يُرجى الرجوع إلى إجراء تقييم أحداث أمن المعلومات لمعرفة تفاصيل كيفية تقييم الأحداث). وفي حالات أخرى، قد يتم الإبلاغ عن الحادث من قبل طرف خارجي كعميل أو مورد أو جهة إنفاذ القانون التي نما إلى علمها وقوع اختراق، ربما بسبب استخدام المعلومات المسروقة بطريقة ما لأغراض ضارة.

وليس من المستغرب وجود فارق زمني بين بداية نشوء الحادث وتوقيت اكتشافه الفعلي؛ وتُعد معالجة هذا التأخير وتقليل هذه المدة الزمنية أحد أهداف نظام إدارة أمن المعلومات (ISMS). ويبقى العامل الأهم هو وجوب البدء في تنفيذ إجراءات الاستجابة للحادث بأسرع وقت ممكن فور اكتشافه، حتى تتسنى الاستجابة له بفاعلية.

3.1 تقييم الأثر (Impact Assessment)

بمجرد اكتشاف الحادث، يجب إجراء تقييم أولي للأثر (يتم ذلك عادةً بواسطة مكتب خدمة تقنية المعلومات من أجل تحديد الاستجابة المناسبة).

يجب أن يُقدّر تقييم الأثر هذا ما يلي:

- مدى التأثير على البنية التحتية لتكنولوجيا المعلومات بما في ذلك الحواسيب، والشبكات، والمعدات، والمرافق/المقرات.
- أصول المعلومات التي قد تكون عرضة للخطر أو التي تعرضت للاختراق.
- المدة الزمنية المحتملة للحادث، أي التوقيت الذي يُرجح أنه بدأ فيه.
- وحدات الأعمال المتأثرة وحجم التأثير الواقع عليها.
- مؤشر أولي حول السبب المحتمل للحادث.

يجب توثيق هذه المعلومات لضمان تكوين فهم زمني واضح للوضع أثناء تطوره، لاستخدامه حالياً وللمراجعة لاحقاً.

كما ينبغي إعداد قائمة بأصول المعلومات، والأنشطة التشغيلية، والمنتجات، والخدمات، والفرق، والعمليات المساندة التي يحتمل أنها تأثرت بالحادث، مرفقةً بتقييم لمدى هذا التأثير.

3.2 تحديد أولويات الحوادث (Incident Prioritisation)

بناءً على نتائج تقييم الأثر، يتم تصنيف الحادث وتحديد مستواه التشغيلي وفق مصفوفة الأولويات المعتمدة في الجدول 1 أدناه:

الأولوية	الوصف والأمثلة المصرفية الواقعية
عالية / حرجية	تعطل جسيم أو تهديد حرج يمس العمليات المصرفية الحيوية أو سلامة أموال وسجلات المودعين. أمثلة واقعية: • تفشي برمجيات الفدية (Ransomware) وتشفير قواعد بيانات النظام المصرفي الأساسي (Core Banking). • اختراق واجهات البرمجة المصرفية (API) وتحويل مبالغ مالية غير مصرح بها أو تسريب بيانات بطاقات الائتمان. • توقف كامل للخدمات المصرفية الرقمية (Mobile/Internet Banking) نتيجة هجوم حجب الخدمة الموزع (DDoS). • اختراق خوادم سويفت (SWIFT) أو شبكة المدفوعات الوطنية (مدى / سريع).

تعطل أو تهديد محلي ومحصور يؤثر على عدة إدارات أو خدمات ثانوية دون المساس بالمعاملات المالية المباشرة. أمثلة واقعية: • فقدان أو سرقة جهاز محمول (Laptop) مشفر بتقنية BitLocker يتبع لأحد الموظفين أثناء السفر. • هجوم تصيد احتيالي موجه استهدف مجموعة موظفين مع احتمال تسريب بيانات اعتماد حسابات عادية. • تعطل مؤقت لنظام إداري داخلي مثل خادم التقارير أو نظام أرشفة الملفات. • رصد انحراف توقيت السجلات (NTP Drift) أو نشاط فحص شبكي مريب تم رصده واعتراضه محلياً.	متوسطة
إزعاج تشغيلي طفيف ومحدود جداً يؤثر على مستخدم واحد أو نظام غير حساس دون أي أثر تجاري أو مالي. أمثلة واقعية: • تنبيه فيروسي اعتيادي تم حجبهِ وعزله آلياً بواسطة برنامج الحماية EDR على محطة عمل فردية. • مخالفة بسيطة لسياسة الاستخدام المقبول (AUP) كاستخدام برنامج غير مصرح لا يحتوي على ثغرات. • قفل مؤقت لحساب مستخدم عادي نتيجة إدخال كلمة مرور خاطئة عدة مرات.	منخفضة

مرجع: الجدول 1: مصفوفة أولويات الحوادث

ونتيجة لهذا التحليل الأولي، يمتلك مكتب خدمة تقنية المعلومات أو أي عضو في فريق الإدارة الصلاحية للاتصال بقائد فريق الاستجابة للحوادث في أي وقت ليطلب منه/منها تقييم ما إذا كان ينبغي تفعيل إجراء الاستجابة لحوادث أمن المعلومات. ويُرجح أن يُطبق ذلك على جميع الحوادث ذات الأولوية العالية (High priority)، والحوادث ذات الأولوية المتوسطة (Medium priority) عندما يُرى ذلك مناسباً.

4 تفعيل إجراءات الاستجابة للحادثة (Activating the Incident Response Procedure)

بمجرد إخطار قائد فريق الاستجابة للحوادث (CISO) بالحادثة، يتولى تقييم نطاق الأثر الفعلي والمحتمل للبت في ضرورة تفعيل الإجراءات الرسمية بمجرد إخطار قائد الفريق بالحادثة، يجب عليه أن يقرر ما إذا كان حجم الحادث وأثره الفعلي أو المحتمل يبرر تفعيل إجراء الاستجابة للحوادث ودعوة فريق الاستجابة للحوادث (IRT) للاجتماع.

سيكون مكتب خدمة تكنولوجيا المعلومات قد أجرى بالفعل تقييماً أولياً للأثر، ومع ذلك، توجد إرشادات إضافية لقائد الفريق لتحديد ما إذا كان ينبغي بدء استجابة رسمية لحادث معين في حال تحقق أي مما يلي:

- وجود فقدان فعلي أو محتمل ذي شأن للمعلومات المصنفة.
- وجود تعطل فعلي أو محتمل كبير في سير العمليات التشغيلية.
- وجود مخاطر جسيمة تهدد سمعة المؤسسة.
- أي حالة أخرى قد تتسبب في تأثير بالغ على المنظمة.

وفي حال حدوث أي خلاف أو عدم يقين بشأن اتخاذ قرار تفعيل الاستجابة للحادث، يكون قرار قائد الفريق نهائياً وحاسماً.

وإذا تقرر عدم تفعيل هذا الإجراء، فينبغي إعداد خطة تتيح استجابة للحادث بمستوى أدنى وضمن القنوات الإدارية المعتادة. وقد يتطلب ذلك تطبيق الإجراءات ذات الصلة على مستوى محلي.

أما إذا كان الحادث يستوجب تفعيل إجراءات الاستجابة للحوادث، فسيبدأ قائد الفريق بحشد وتجميع أعضاء فريق الاستجابة للحوادث (IRT).

5 تشكيل فريق الاستجابة للحوادث (Assemble Incident Response Team)

بمجرد اتخاذ القرار بتنفيذ إجراء الاستجابة للحوادث، سيتأكد قائد الفريق (أو نائبه) من التواصل مع جميع أصحاب الأدوار المحددة (أو نوابهم إذا تعذر الوصول إلى أصحاب الأدوار الرئيسيين)، وإحاطتهم بطبيعة الحادث، وطلب تواجدهم إما بالتجمع في موقع مناسب أو الانضمام إلى اجتماع افتراضي.

ويُستثنى من ذلك مسؤول الاتصال بالحادث (Incident Liaison)، حيث سيُطلب منه الحضور إلى موقع الحادث مباشرة (إذا كان مختلفاً ومناسباً) للبدء في جمع المعلومات اللازمة لتقييم الحادث الذي سيجريه فريق الاستجابة للحوادث (IRT)، ليتسنى تحديد الاستجابة المناسبة.

5.1 أعضاء فريق الاستجابة للحوادث (Incident Response Team Members)

يتشكل فريق الاستجابة لحوادث أمن المعلومات (IRT) في بنك الأفاق الرقمية من الأعضاء الرئيسيين ونوابهم الموضحين في الجدول 2 أدناه:

الدور / المجال الوظيفي	شاغل الدور الرئيسي	النائب المعين
قائد الفريق	أ. سارة الحربي (مدير أمن المعلومات - CISO)	محمد عبدالغني العامري (كبير أخصائيي الأمن السيبراني)
ميسر ومنسق الفريق	م. فيصل القحطاني (منسق الحوادث وإدارة الأزمات)	أ. نورة الشهري (أخصائية حوكمة أمن المعلومات)
منسق الحادث الميداني	م. فهد الشمري (رئيس فريق الأدلة الجنائية بمركز SOC)	م. خالد المطيري (مهندس أول استجابة للحوادث)
تقنية المعلومات	م. خالد السالم (مدير إدارة تقنية المعلومات - CTO)	م. طارق العتيبي (مدير هندسة البنية التحتية)
العمليات المصرفية	أ. فهد العتيبي (مدير إدارة العمليات المصرفية الأساسية)	أ. سلطان الغامدي (رئيس عمليات التحويل والمدفوعات)
إدارة المرافق والأمن المادي	أ. عبدالله الدوسري (مدير المرافق والسلامة المادية)	أ. سعد الحربي (مشرف أمن مراكز البيانات)
الصحة والسلامة والبيئة	أ. ماجد الخالدي (مسؤول السلامة والصحة المهنية)	أ. بدر العنزي (أخصائي السلامة والطوارئ)
الموارد البشرية	أ. منى الشريف (مديرة إدارة الموارد البشرية HR)	أ. حصة المنصور (رئيسة علاقات الموظفين)
استمرارية الأعمال	أ. ريان السبيعي (مدير إدارة استمرارية الأعمال والتعافي)	أ. زياد الرشيد (أخصائي استمرارية الأعمال)
الاتصال والإعلام	أ. مشعل الرويلي (مدير إدارة الاتصال المؤسسي)	أ. لمى التميمي (مشرفة العلاقات العامة والإعلام)

المحاميه مها العتيبي (مستشارة الالتزام المصرفي)	المستشار إبراهيم باوزير (رئيس الشؤون القانونية)	الشؤون القانونية والالتزام
---	---	----------------------------

5.2 الأدوار والمسؤوليات (Roles and Responsibilities)

تحدد هذه السياسة بدقة الواجبات والمهام الممنوعة بكل عضو من أعضاء فريق الاستجابة للحوادث:

5.2.1 قائد الفريق (Team Leader):

- يقرر ما إذا كان سيتم بدء وتفعيل الاستجابة للحوادث.
- يحشد ويجمع أعضاء فريق الاستجابة للحوادث.
- يتولى الإدارة الشاملة لفريق الاستجابة للحوادث.
- يعمل كنقطة تواصل مع مجلس الإدارة وأصحاب المصلحة رفيعي المستوى.
- صاحب القرار النهائي في حالات الخلاف أو عدم الاتفاق.

5.2.2 ميسر الفريق (Team Facilitator):

- يدعم فريق الاستجابة للحوادث.
- ينسق الموارد داخل مركز القيادة / غرفة العمليات.
- يجهز للاجتماعات ويدون سجل الإجراءات والقرارات.
- يحيط أعضاء الفريق بآخر المستجدات فور عودتهم إلى مركز القيادة / غرفة العمليات.
- يسهل عمليات التواصل عبر البريد الإلكتروني أو الفاكس أو الهاتف أو غيرها من الوسائل.
- يتابع مصادر تدفق المعلومات الخارجية مثل نشرات الأخبار.

5.2.3 منسق الحادث الميداني (Incident Liaison):

- يتواجد في موقع الحادث بأسرع ما يمكن.
- يقيم حجم الحادث ومدى تأثيره.
- يقدم إفادة ميدانية مباشرة عن الموقف لفريق الاستجابة للحوادث (IRT).
- ينسق ويتواصل مع فريق الاستجابة للحوادث بصفة مستمرة لتقديم التحديثات والإجابة عن أي استفسارات لازمة لاتخاذ القرارات من قبل الفريق.

5.2.4 تقنية المعلومات (Information Technology):

- يقدم الآراء والمدخلات الفنية بشأن المشكلات المتعلقة بالتقنية.
- يساعد في تقييم أثر الحادث.

5.2.5 العمليات المصرفية (Business Operations):

- يساهم في اتخاذ القرارات بناءً على معرفته بالعمليات التشغيلية، والمنتجات، والخدمات.
- يحيط ببقية أعضاء الفريق علماً بالقضايا التشغيلية.
- يساعد في تقييم الأثر المحتمل على عملاء المنظمة.

5.2.6 إدارة المرافق (Facilities Management):

- يتعامل مع جوانب الأمن المادي وإدارة الدخول والوصول إلى المرافق.
- يوفر التواجد والحراسة الأمنية إذا تطلب الأمر.

5.2.7 الصحة والسلامة (Health and Safety):

- يقيم المخاطر الناجمة عن الحادث على الأرواح والسلامة الجسدية.
- يضمن الامتثال الدائم للمسؤوليات القانونية المتعلقة بالصحة والسلامة.

- ينسق مع خدمات الطوارئ مثل الشرطة والإطفاء والجهات الطبية.
- يراعي القضايا والآثار البيئية المرتبطة بالحادث.

5.2.8 الموارد البشرية (Human Resources):

- يقيم ويقدم المشورة بشأن سياسات الموارد البشرية وشؤون عقود العمل.
- يمثل مصالح موظفي المنظمة.
- يقدم المشورة والتوجيه بشأن قضايا الكفاءة والإجراءات التأديبية.

5.2.9 استمرارية الأعمال (Business Continuity Planning):

- يقيم ويقدم المشورة بشأن سياسات الموارد البشرية وشؤون عقود العمل.
- يمثل مصالح موظفي المنظمة.
- يقدم المشورة والتوجيه بشأن قضايا الكفاءة والإجراءات التأديبية.

5.2.10 الاتصال المؤسسي والإعلام (Communications):

- مسؤول عن ضمان فاعلية الاتصالات الداخلية.
- يحدد مستوى وتكرار ومحتوى التواصل مع الأطراف الخارجية مثل وسائل الإعلام.
- يحدد النهج المتبع لإبقاء الأطراف المتأثرة على اطلاع دائم (مثل العملاء والمساهمين).

5.2.11 الشؤون القانونية والالتزام (Legal and Regulatory):

- يقدم المشورة بشأن الإجراءات الواجب اتخاذها لضمان الامتثال للقوانين والأطر التنظيمية ذات الصلة.
- يقيم التبعات والآثار القانونية الفعلية والمحتملة للحوادث ولإجراءات المترتبة عليه.
- يتواصل مع شركات التأمين لتقييم المطالبات والحصول على موارد إضافية.

5.3 مصفوفة المسؤوليات (RACI Matrix)

يوضح الجدول أدناه من هو المسؤول عن التنفيذ (R)، أو الخاضع للمساءلة (A)، أو المُستشار (C)، أو المُبلِّغ (I) في المراحل المختلفة من هذا الإجراء.

EM	LR	CO	CP	HR	HS	FM	BO	IT	IL	TF	TL	المهمة (TASK)
R	I	I	I	I	R	R	C	I	R	R	A	اكتشاف الحادث
I	I	I	C	I	C	C	C	C	R	R	A	تحليل الحادث
I	C	C	C	C	C	C	C	C	C	R	A	تشكيل الفريق
I	I	I	I	I	R	R	R	C	R	R	A	الاحتواء
I	I	I	C	I	R	R	R	C	R	R	A	الاستئصال
I	C	I	C	C	R	R	A	C	C	C	R	التعافي
I	C	R	C	R	C	C	C	C	C	C	A	التواصل الداخلي
I	C	R	C	C	C	C	C	C	C	C	A	التواصل الخارجي
I	R	C	I	C	C	C	C	R	C	C	A	الإشعار والتبليغ
C	C	I	C	C	C	C	C	C	C	R	A	تقرير الحادث
C	C	C	C	C	C	C	C	C	C	R	A	المراجعة اللاحقة

مرجع: 3: مصفوفة توزيع المسؤوليات (Table 3: RACI matrix)

5.4 إدارة الحادث ومراقبته والاتصالات (Incident Management & Monitoring)

بمجرد تحديد الاستجابة المناسبة للحادث، يجب أن يكون فريق الاستجابة للحوادث (IRT) قادراً على إدارة خطة الاستجابة الشاملة، ومتابعة حالة الحادث، وضمان سير التواصل الفعال على كافة المستويات.

يجب عقد اجتماعات دورية لفريق الاستجابة للحوادث بوتيرة يحددها قائد الفريق، ويرد جدول الأعمال القياسي لهذه الاجتماعات في الملحق (ج). والهدف من هذه الاجتماعات هو ضمان إدارة موارد التعامل مع الحادث بكفاءة، واتخاذ القرارات الأساسية بسرعة استناداً إلى معلومات كافية. وسيتولى الفريق تدوين محضر كل اجتماع.

سيقدم مسؤول الاتصال بالحادث تحديثات دورية لفريق الاستجابة للحوادث وفق وتيرة يحددها قائد الفريق. ويجب تنسيق مواعيد هذه التحديثات مع اجتماعات الفريق لضمان توفر أحدث المعلومات في كل اجتماع.

5.5 إجراءات التواصل (Communication Procedures):

من الضروري للغاية الحفاظ على تواصل فعال بين جميع الأطراف المشاركة في الاستجابة للحادث.

بناءً على مقتضيات الموقف، قد تكون وسيلة التواصل الافتراضية أثناء الحادث وجهاً لوجه، أو عبر الهاتف، أو من خلال أدوات التعاون والعمل الجماعي مثل فريق الاتصال المؤسسي والعلاقات العامة والاعلام، وذلك وفقاً لما يحدده قائد الفريق. كما يجب عدم استخدام البريد الإلكتروني إلا بعد الحصول على إذن صريح بذلك من فريق الاستجابة للحوادث (IRT).

يجب اتباع الإرشادات التالية في كافة الاتصالات:

- التحلي بالهدوء وتجنب الأحاديث الطويلة غير الضرورية.
- إبلاغ أعضاء الفريق الداخليين بضرورة إحالة أي طلبات للحصول على معلومات إلى فريق الاستجابة للحوادث.
- في حال الرد على المكالمات من قبل شخص آخر غير جهة الاتصال المطلوبة:

- الاستفسار عما إذا كان بالإمكان الوصول إلى الشخص المطلوب في مكان آخر.
- في حال تعذر الوصول إليه، ترك رسالة تطلب منه الاتصال بك على رقم محدد.
- عدم الإفصاح عن أي تفاصيل تخص الحادث.

• توثيق تفاصيل توقيت المكالمات والردود والإجراءات المتخذة دائماً.

يجب تسجيل وتدوين جميع الاتصالات بوضوح ودقة؛ حيث قد يُطلب الرجوع إلى هذه السجلات ضمن إجراءات قانونية في وقت لاحق.

5.1.1 الاتصالات الخارجية (External communication):

بناءً على طبيعة الحادث، قد يكون هناك أطراف خارجية متعددة يتم التواصل معها خلال مجريات الاستجابة. ومن الضروري إدارة المعلومات الصادرة إلى الجهات الخارجية لضمان نشرها في الوقت المناسب وبدقة تامة.

يجب تحويل المكالمات الواردة من جهات غير مشاركة مباشرة في جهود الاستجابة للحادث (مثل وسائل الإعلام) إلى عضو فريق الاستجابة للحوادث المسؤول عن الاتصالات.

قد يوجد عدد من الأطراف الخارجية التي قد تتأثر بالحادث رغم عدم تورطها أو مشاركتها المباشرة فيه، ويجب إخطارها وتنبيهها بذلك. وقد تشمل هذه الجهات:

- العملاء
- الموردين
- المساهمين
- الهيئات التنظيمية
- السلطات الإشرافية والرقابية
- شركات التأمين

ينبغي لعضو فريق الاستجابة للحوادث المكلف بالاتصالات إعداد قائمة بهذه الأطراف المعنية وتحديد صياغة الرسالة الموجهة إليهم. وترد قائمة ببعض الجهات الخارجية في الملحق (ب).

قد يبادر أصحاب المصلحة والأطراف المعنية الذين لم يتم إخطارهم من قبل الفريق بالاتصال للحصول على معلومات حول الحادث وتداعياته؛ لذا يجب تدوين هذه المكالمات في سجل الرسائل وتحويلها إلى مسؤول الاتصالات في فريق الاستجابة للحوادث.

5.5.2 التواصل مع وسائل الإعلام (Communication with the Media)

بشكل عام، تتمثل استراتيجية التواصل فيما يتعلق بوسائل الإعلام في إصدار التحديثات عن طريق الإدارة العليا. ولا يجوز لأي موظف إجراء مقابلة مع وسائل الإعلام ما لم يحصل على تصريح مسبق بذلك من قبل فريق الاستجابة للحوادث (IRT).

وتتمثل الوسيلة المفضلة للتواصل مع وسائل الإعلام في إصدار بيانات صحفية مكتوبة مسبقاً ومعدة بعناية. وفي الظروف الاستثنائية، قد يُعقد مؤتمر صحفي للإجابة عن التساؤلات المتعلقة بالحادث وتداعياته. ويقع على عاتق عضو فريق الاستجابة للحوادث المسؤول عن الاتصالات ترتيب مكان انعقاد تلك المؤتمرات والتنسيق مع ممثلي الصحافة الراغبين في الحضور.

يُحظر حظراً قاطعاً على أي موظف أو مسؤول الإدلاء بأي تصريح صحفي أو إعلامي إلا للمتحدثين الرسميين المفوضين في الجدول 4 أدناه، وبناءً على خطورة الحادث:

الاسم	الدور والصفة	نطاق وحجم الحادث المسموح به
أ. مشعل الرويلي	أخصائي الاتصال المؤسسي بفريق IRT	الحوادث المنخفضة (Low) — بيانات صحفية روتينية وإجابات محددة
أ. لمى التميمي	مديرة إدارة العلاقات العامة والإعلام	الحوادث المتوسطة (Medium) — بيانات رسمية للجمهور والموقع
د. نورة القحطاني	الرئيس التنفيذي للبنك (CEO)	الحوادث العالية والدرجة (High / Critical) — مؤتمرات صحفية ولقاءات إعلامية

يعتمد اختيار المتحدث الرسمي الأنسب على حجم الحادث ومدى تأثيره على العملاء، والموردين، والجمهور، وغيرهم من أصحاب المصلحة.

6 احتواء الحادث واستنصاله والتعافي منه والإشعار (Containment, Eradication, Recovery & Notification)

يصف هذا القسم الخطوات الرئيسية المتبعة في إدارة الحادث. وتتوفر إجراءات وخطط إضافية لتغطية تفاصيل هذه الخطوات لأنواع محددة من الحوادث، على سبيل المثال: برمجيات الفدية (Ransomware)، وهجمات حجب الخدمة (Denial of Service)، واختراق البيانات (Data Breach).

6.1 الاحتواء والحفاظ على الأدلة الجنائية الرقمية (Containment & Digital Forensics)

تتمثل الخطوة الأولى في محاولة منع تفاقم الحادث، أي احتواؤه (Containment). وفي حالة تفشي الفيروسات، قد يتطلب ذلك فصل الأجزاء المتأثرة من الشبكة؛ أما في حالة التعرض لهجوم اختراق، فقد يستدعي الأمر تعطيل ملفات تعريف أو منافذ معينة على جدار الحماية (Firewall)، أو ربما فصل الشبكة الداخلية عن شبكة الإنترنت بالكامل. وتعتمد الإجراءات المحددة الواجب تنفيذها على ظروف وملابسات الحادث.

ملاحظة: إذا رُني أنه من المحتمل جمع أدلة رقمية لاستخدامها لاحقاً في المحكمة، فيجب اتخاذ الاحتياطات اللازمة لضمان بقاء هذه الأدلة مقبولة قانونياً (Admissible). وهذا يعني عدم تغيير أو تعديل البيانات ذات الصلة، سواء كان ذلك عمداً أو عن طريق الخطأ، كإيقاف حاسوب محمول من وضع السكون مثلاً. ويوصى بالاستعانة بمشورة المتخصصين في هذه المرحلة (انظر بيانات الاتصال في الملحق ب).

وعلى وجه الخصوص (دون حصر)، إذا كان هناك اشتباه في وجود عمل تخريبي أو جرمي، فيجب الاحتفاظ بسجلات دقيقة للإجراءات المتخذة والأدلة التي تم جمعها، بما يتوافق مع الإرشادات التوجيهية للتحقيق الجنائي الرقمي (Digital Forensics). وتتمثل المبادئ الرئيسية لهذه الإرشادات فيما يلي:

- المبدأ 1: عدم تغيير أي بيانات؛ فإذا تم اتخاذ أي إجراء يؤدي إلى تعديل البيانات على النظام المعني بأي شكل من الأشكال، فسيؤثر ذلك سلباً على أي دعوى قضائية لاحقة.
- المبدأ 2: عدم الوصول إلى البيانات الأصلية إلا في الظروف الاستثنائية؛ حيث سيستخدم اختصاصي مدرب أدوات متخصصة لأخذ نسخة متطابقة بت ببت (Bit-stream copy) لأي بيانات موجودة في الذاكرة، سواء كانت على قرص صلب، أو ذاكرة فلاشية، أو شريحة هاتف (SIM). ويتم بعد ذلك إجراء كافة التحليلات على هذه النسخة، مع عدم لمس الأصل نهائياً إلا في حالات استثنائية، كأن يكون عامل الوقت حاسماً وكان الحصول على المعلومات لمنع وقوع جريمة أخرى أهم من قبول الدليل أمام المحكمة.
- المبدأ 3: الاحتفاظ دائماً بسجل تدقيق (Audit trail) يوضح ما تم تنفيذه؛ وتقوم الأدوات الجنائية بذلك تلقائياً، ولكن هذا ينطبق أيضاً على المستجيبين الأوائل في موقع الحادث. ويُشجع على التقاط الصور وتسجيل مقاطع الفيديو طالما لم يتم لمس أو تحريك أي شيء أثناء ذلك.
- المبدأ 4: يجب على الشخص المسؤول ضمان الالتزام التام بتطبيق هذه الإرشادات.

وقبل وصول المختص، ينبغي جمع المعلومات الأساسية، والتي قد تشمل:

- صور فوتوغرافية أو مقاطع فيديو للرسائل أو المعلومات ذات الصلة.
- سجلات مكتوبة يدوياً للتسلسل الزمني لمجريات الحادث.
- الوثائق الأصلية، مع توثيق من عثر عليها، وأين، ومتى.
- بيانات وتفاصيل أي شهود.

وبمجرد جمع الأدلة، سيتم حفظها في مكان آمن ومحمي من العبث، مع إنشاء وتوثيق سلسلة حيازة رسمية (Chain of Custody).

وقد تكون الأدلة مطلوبة للأغراض التالية:

- للتحليل اللاحق لتحديد الأسباب الجذرية للحادث.
- كأدلة جنائية لإجراءات المحاكم المدنية أو الجنائية.
- لدعم أي مفاوضات للحصول على تعويضات مع موردي البرمجيات أو مقدمي الخدمات.

عقب ذلك، يتعين تكوين صورة واضحة وشاملة لما حدث؛ إذ ينبغي التحقق من حجم الحادث والتبعات المترتبة عليه قبل اتخاذ أي إجراء احتواء. كما يمكن فحص سجلات التدقيق (Audit logs) لترتيب التسلسل الزمني للأحداث، مع الحرص التام على استخدام نسخ آمنة من السجلات التي لم تتعرض لأي تلاعب أو عبث.

6.2 الاستئصال وإزالة التهديد (Eradication)

يجب إخضاع الإجراءات المتبعة لمعالجة الأضرار الناجمة عن الحادث، مثل إزالة البرمجيات الضارة (Malware)، لعملية إدارة التغيير (Change Management) (والتي ستتم على الأرجح كتغيير طارئ). وينبغي أن تهدف هذه الإجراءات إلى معالجة السبب الحالي ومنع تكرار الحادث مستقبلاً، مع ضرورة تحديد أي ثغرات أمنية تم استغلالها كجزء من هذا الحادث.

واعتماداً على نوع الحادث، قد لا تكون مرحلة الاستئصال (Eradication) ضرورية في بعض الأحيان.

6.3 التعافي واستعادة العمليات (Recovery)

خلال مرحلة التعافي (Recovery)، يجب استعادة الأنظمة إلى حالتها التي كانت عليها قبل وقوع الحادث، مع اتخاذ الإجراءات اللازمة لمعالجة أي ثغرات أمنية تم استغلالها كجزء من هذا الحادث. وقد يشمل ذلك أنشطة مثل تثبيت التصحيحات الأمنية (Patches)، وتغيير كلمات المرور، وتحسين الخوادم (Hardening)، وتعديل الإجراءات المتبعة.

6.4 الإشعار والتبليغ النظامي (Notification)

يُعد الإخطار بوقوع حادث أمن معلومات وما ينجم عنه من فقدان للبيانات مسألة حساسة يجب التعامل معها بحذر شديد وبموافقة كاملة من الإدارة. وسيحدد فريق الاستجابة للحوادث (IRT) — استناداً إلى المشورة القانونية واستشارات الخبراء الآخرين، ومع تكوين أوضح فهم ممكن لأثر الحادث — ما إذا كان الإخطار مطلوباً، وتوقيت إرساله، والشكل الذي سيخذه. وفيما يخص الانتهاكات التي تمس البيانات الشخصية، يُرجى الرجوع إلى وثيقة "إجراء الإخطار بانتهاك البيانات الشخصية" ونموذج "خطاب الإخطار بانتهاك لأصحاب البيانات".

ستلتزم بنك الأفاق دائماً وبالكامل بالمتطلبات القانونية والتنظيمية المعمول بها بخصوص الإخطار عن الحوادث، وستتقّم بعناية أي خدمات تعويضية يمكن تقديمها للأطراف التي قد تتأثر بالحادث، مثل خدمات مراقبة الائتمان (Credit monitoring services).

وقد تُطلب السجلات التي جُمعت كجزء من إجراءات الاستجابة للحادث ضمن أي تحقيقات تترتب على ذلك وتجريها الهيئات التنظيمية المعنية، وستتعاون بنك الأفاق بشكل كامل مع تلك الإجراءات.

7 أنشطة ما بعد الحادث والدروس المستفادة (Post-Incident Activity)

سيقرر قائد الفريق، بناءً على أحدث المعلومات الواردة من مسؤول الاتصال بالحادث وبقية أعضاء الفريق، التوقيت المناسب لإيقاف أنشطة الاستجابة وإنهاء حالة الاستنفار لفريق الاستجابة للحوادث (IRT). ويُرجى ملاحظة أن عمليات التعافي وتنفيذ الخطط قد تستمر بعد هذه المرحلة، ولكن تحت إشراف إداري أقل رسمية.

ويخضع هذا القرار لتقدير قائد الفريق، على أن يستند إلى المعايير التالية:

- تم حل الموقف بالكامل أو استقراره بدرجة مقبولة ومعقولة.
- تباطؤ وتيرة التغيرات في الموقف إلى حد لا يتطلب سوى قرارات قليلة.
- سير خطة الاستجابة المناسبة بصورة جيدة، وتقدم خطط التعافي وفق الجدول الزمني المحدد.
- تراجع مستوى الخطر المهدد للأعمال إلى حد مقبول.
- الوفاء بالمسؤوليات القانونية والتنظيمية الفورية.

وفي حال استمرار مرحلة التعافي من الحادث، يتعين على قائد الفريق تحديد الإجراءات اللاحقة الواجب اتخاذها، والتي قد تشمل:

- تقليل وتيرة اجتماعات فريق الاستجابة للحوادث (كأن تصبح أسبوعية مثلاً، تبعاً لمقتضيات الظروف).
- إبلاغ جميع الأطراف المعنية بإنهاء استنفار فريق الاستجابة للحوادث.
- التأكد من حفظ وتأمين كافة الوثائق والمستندات الخاصة بالحادث.
- مطالبة جميع الموظفين غير المشاركين في مهام المتابعة الإضافية بالعودة إلى أداء أعمالهم المعتادة.
- يجب تسجيل وتوثيق جميع الإجراءات المتخذة في مرحلة إنهاء الاستنفار.

وبعد توجيه الأمر بإنهاء استنفار الفريق، سيعقد قائد الفريق اجتماعاً لاستخلاص المعلومات وتقييم الموقف (Debrief) لجميع الأعضاء، ويُفضل أن يتم ذلك في غضون 24 ساعة. وسيقوم فريق الاستجابة بفحص ومراجعة سجلات الحادث المعنية لضمان مطابقتها لما جرى فعلياً، ولكونها تمثل سجلاً شاملاً ودقيقاً للحادث.

كما سيتم تدوين أي ملاحظات أو مرنيات فورية يطرحها أعضاء الفريق.

وسيتم عقد مراجعة رسمية شاملة لما بعد الحادث (Post-incident review) في موعد تحدده الإدارة العليا وفقاً لحجم وطبيعة الحادث.

8 الملحق أ: استمارة جهات الاتصال للاستجابة الأولية (Appendix A: Initial Response Contact Sheet)

ينبغي استخدام الجدول أدناه لتسجيل محاولات الاتصال المبدئي (الناجحة وغير الناجحة) بأعضاء فريق الاستجابة للحوادث (IRT).
ملاحظة: بالنسبة لعمود "النتيجة" (Outcome)، اختر من بين: "تم التواصل" (Contacted)، أو "لا يوجد رد" (No answer)، أو "تم ترك رسالة" (Message left)، أو "تعذر الوصول" (Unreachable).

الاسم	الدور في الخطة	هاتف المكتب	الهاتف المنزلي	الهاتف المحمول	التاريخ والوقت	النتيجة	وقت الوصول
أ. سارة الحربي	قائد الفريق (TL)	400 11 966+ 1101	11 966+ 2201 477	123 50 966+ 4501	2026/09/12 08:15	تم الاتصال	فوري (15 دقيقة)
م. فيصل القحطاني	ميسر الفريق (TF)	400 11 966+ 1102	11 966+ 2202 477	123 50 966+ 4502	2026/09/12 08:17	تم الاتصال	20 دقيقة
م. فهد الشمري	المنسق الميداني (IL)	400 11 966+ 1103	11 966+ 2203 477	123 50 966+ 4503	2026/09/12 08:16	تم الاتصال	متواجد بالمقر (SOC)
م. خالد السالم	تقنية المعلومات (IT)	400 11 966+ 1104	11 966+ 2204 477	123 50 966+ 4504	2026/09/12 08:18	تم الاتصال	15 دقيقة
أ. فهد العتيبي	العمليات (BO)	400 11 966+ 1105	11 966+ 2205 477	123 50 966+ 4505	2026/09/12 08:20	تم الاتصال	25 دقيقة
أ. عبدالله الدوسري	المرافق (FM)	400 11 966+ 1106	11 966+ 2206 477	123 50 966+ 4506	2026/09/12 08:21	تم الاتصال	20 دقيقة
أ. ماجد الخالدي	السلامة والصحة (HS)	400 11 966+ 1107	11 966+ 2207 477	123 50 966+ 4507	2026/09/12 08:22	تم الاتصال	30 دقيقة
أ. منى الشريف	الموارد البشرية (HR)	400 11 966+ 1108	11 966+ 2208 477	123 50 966+ 4508	2026/09/12 08:23	تم الاتصال	20 دقيقة
أ. ريان السبيعي	استمرارية الأعمال (CP)	400 11 966+ 1109	11 966+ 2209 477	123 50 966+ 4509	2026/09/12 08:19	تم الاتصال	15 دقيقة
أ. مشعل الرويلي	الاتصال والإعلام (CO)	400 11 966+ 1110	11 966+ 2210 477	123 50 966+ 4510	2026/09/12 08:24	تم الاتصال	25 دقيقة
المستشار إبراهيم باوزير	الشؤون القانونية (LR)	400 11 966+ 1111	11 966+ 2211 477	123 50 966+ 4511	2026/09/12 08:25	تم الاتصال	20 دقيقة

مرجع: الجدول 5: استمارة جهات الاتصال للاستجابة الأولية (Table 5: Initial response contact sheet)

9 الملحق ب: جهات الاتصال الخارجية المفيدة (Appendix B: Useful External Contacts)

يوضح الجدول التالي بيانات الاتصال الخاصة بالأطراف الخارجية التي قد تكون مفيدة تبعاً لطبيعة الحادث:

المنظمة / الجهة	الممثل / جهة الاتصال	رقم الهاتف	البريد الإلكتروني
شركة التحقيق الجنائي السيبراني	فريق الاستجابة السريعة لحوادث الخروقات	3344 222 11 966+	dfir-support@cyberpartner.sa
مورد حلول الحماية الأمنية	فريق الدعم الفني المتقدم للمؤسسات	6677 555 11 966+	enterprise-soc@securityvendor.sa
الجهات الأمنية والشرطة	إدارة الجرائم الإلكترونية (الأمن العام)	444 11 966+ / 999 8888	cybercrime@moi.gov.sa
المركز الوطني للأمن السيبراني	غرفة طوارئ الحوادث السيبرانية الوطنية	829 11 966+ / 199099 9999	incident@cert.gov.sa
مزود خدمة الإنترنت والاتصالات	فريق دعم خطوط البيانات والد DoS السحابي	455 11 966+ / 909 5555	corporate-noc@stc.com.sa
شركة التأمين السيبراني (شركة التعاونية)	إدارة مطالبات وتغطيات المخاطر السيبرانية	5800 252 11 966+	cyber-claims@tawuniya.com.sa
وكالة العلاقات العامة وإدارة الأزمات	كبير مستشاري الإعلام في الأزمات	9900 488 11 966+	crisis-pr@ofok-media.sa
ممثلو العملاء والمودعين	إدارة رعاية عملاء بنك الأفاق الرقمية	1999 400 11 966+	customer-care@dhb.sa
اتحاد المصارف السعودية	لجنة أمن المعلومات المصرفية المشتركة	3200 405 11 966+	banking-security@fsc.org.sa
الجهة التنظيمية والرقابية (البنك المركزي السعودي - SAMA)	إدارة الرقابة والإشراف على الأمن السيبراني	3000 463 11 966+	cyber-incident@sama.gov.sa

مرجع: الجدول 6: جهات الاتصال الخارجية المفيدة (Table 6: Useful external contacts)

10 الملحق ج: جدول الأعمال القياسي لاجتماعات الفريق (Appendix C: Standard IRT Meeting Agenda)

يُوصى باستخدام جدول الأعمال القياسي التالي لاجتماعات فريق الاستجابة للحوادث.

جدول الأعمال (AGENDA)

الحاضرون: جميع أعضاء فريق الاستجابة للحوادث

الموقع: (Location): غرفة القيادة / غرفة إدارة الأزمات / (Command Centre / War Room) اجتماع عبر الإنترنت) .
دورية الاجتماع: (Frequency): كل أربع ساعات.

رئيس الاجتماع: قائد الفريق

تدوين المحضر: منسق الفريق

1. الإجراءات الناتجة عن الاجتماع السابق
2. تحديثات حالة الحادث
3. القرارات المطلوبة
4. توزيع المهام
5. الاتصالات الداخلية
6. الاتصالات الخارجية
7. إنهاء حالة الاستنفار (Standing down)
8. ما يستجد من أعمال (Any other business)